

Cours de Sécurité IoT

**Enseignant Responsable:
Maroua Abdelhafidh**

Auditoire: IoT3

AU 2025/2026

Plan de cours

Chapitre 1: Introduction à la Sécurité de l'IoT

Chapitre 2: Sécurité Couche Physique

Chapitre 3: Sécurité Couche Réseau

Chapitre 4: Sécurité Couche Application

CHAPITRE 1 : Introduction à la sécurité IoT

1. Définition IoT
2. Fonctionnement IoT
3. Les éléments de l'IoT
4. Architecture IoT
5. Importance de sécurité dans l'IoT
6. Attaques emblématiques dans l'IoT
7. Les services de sécurité IoT

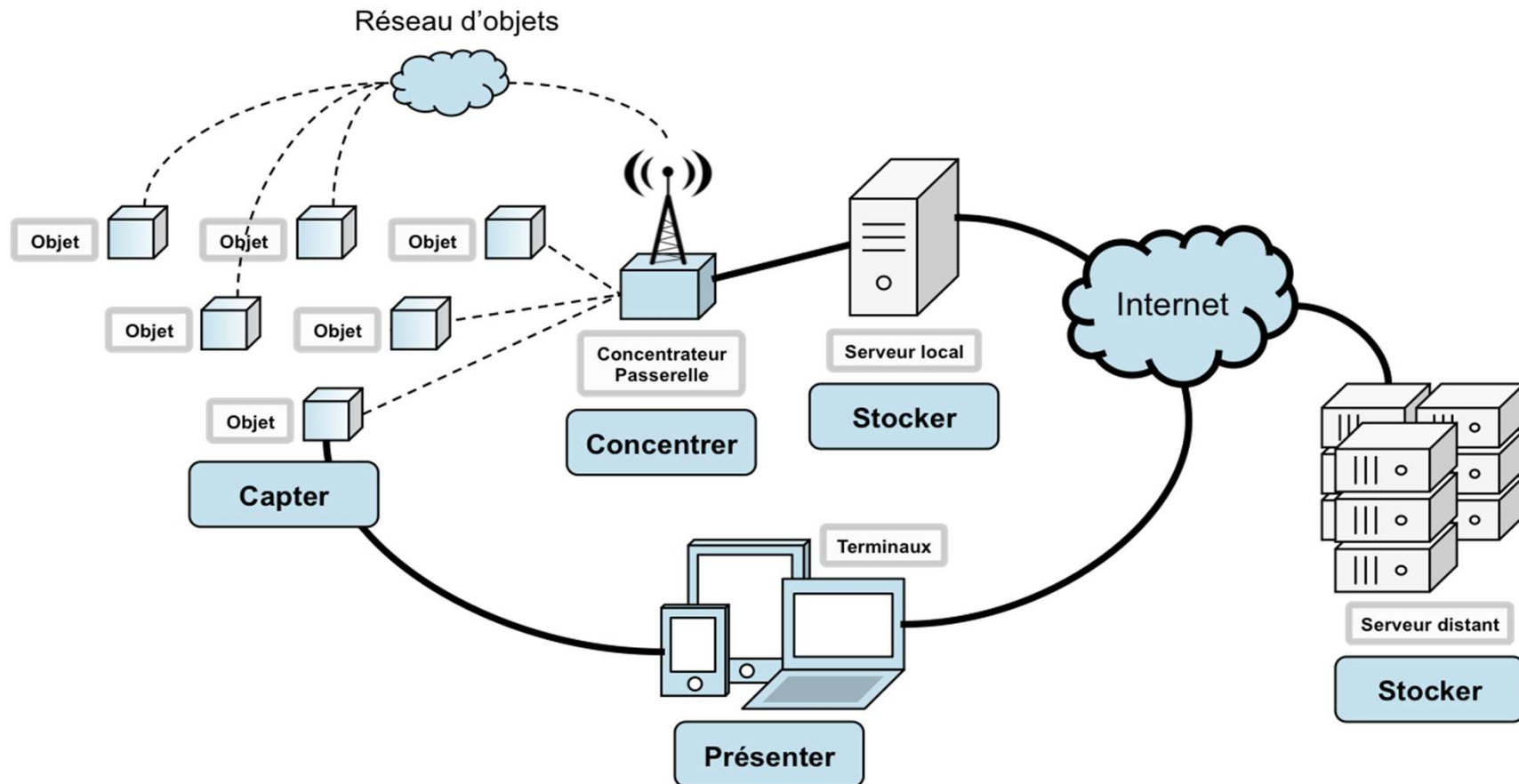
1.1 Internet of Things_Définition

L'IoT est vu comme l'évolution du futur Internet. On peut le définir comme un ensemble d'objets capables d'avoir une identité propre, de fonctionner dans des environnements intelligents et de communiquer entre eux grâce à des interfaces connectées.



➡ **Objectifs** : automatisation, supervision, contrôle à distance.

1.2 Internet of Things_Fonctionnement



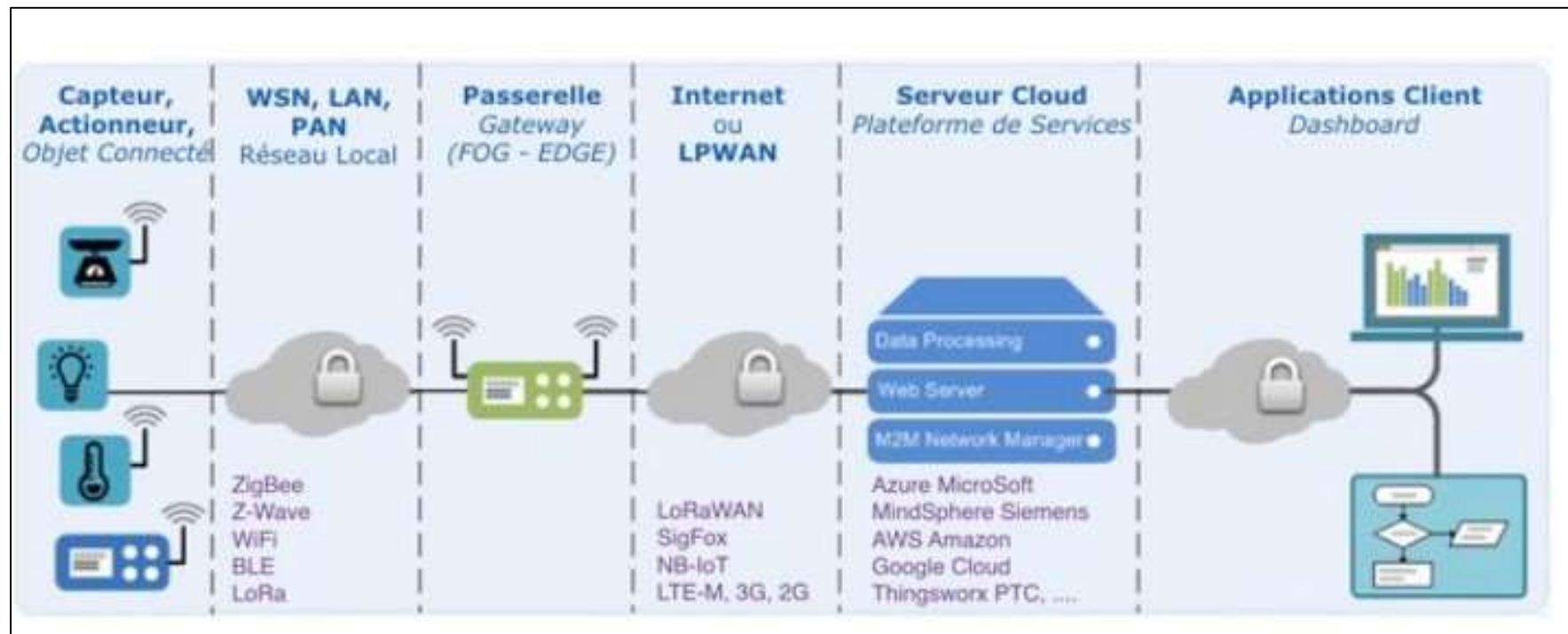
La chaîne de données IoT, depuis les capteurs jusqu'aux actionneurs.

1.3 Internet of Things_ Les éléments de l' IoT

Élément	Besoin Fonctionnel	Technologies utilisées
Identification	Attribution d'une identité unique aux objets	RFID, Electronic Code Product (ECP) IPv4 et IPv6
Capture/Détection	Collecte de données via des capteurs adaptés	Capteurs, Capteurs portés Capteurs intelligents, actionneur, etc.
Communication	Envoie et réception des messages, des fichiers et d'autres informations	Wi-Fi, Bluetooth, LoRa, ZigBee, 4G/5G, Near Field Communication (NFC), Long Term Evolution (LTE)
Calcul	Traitement et stockage des données collectées.	Edge Computing, Cloud Computing, Bases de données SQL/NoSQL, IA, Machine Learning
Services	Mise à disposition des données pour exploitation	Applications mobiles, Tableaux de bord,...
Analyses	Exploitation des données pour en extraire de la valeur.	Big Data, IA, Machine Learning, Algorithmes prédictifs, Visualisation de données

1.4 Internet of Things_Architecture IoT simplifiée

- Une **solution IoT** est composée de plusieurs couches interconnectées qui permettent de relier le monde physique des appareils au monde digital.



1.4 Internet of Things _ Architecture IoT simplifiée

Composantes de l'IoT

- **Capteurs** : dispositifs qui transforment une grandeur physique (température, luminosité, etc.) en données numériques exploitables par des logiciels et collectent les informations du monde réel.
- **Actionneurs** : dispositifs qui transforment des données numériques en phénomènes physiques pour créer une action, à l'inverse des capteurs (ex. : lampes, moteurs, pompes, serrures, haut-parleurs...).
- **Passerelles / Gateways** : elles connectent les objets au réseau, choisissant le type adapté (2G/3G/4G ou bas débit comme Sigfox, NB-IoT) et effectuent un pré-traitement des données.

1.4 Internet of Things _ Architecture IoT simplifiée

Composantes de l'IoT

- **Passerelles / Gateways** : Différentes solutions de connectivité permettent aux objets de communiquer. Selon leur nature et les données captées, il faut choisir le bon réseau (2G/3G/4G ou bas débit type Sigfox, NB-IoT) qui relie les objets et effectue un pré-traitement des données.
- **Cloud / Serveurs** : Le cloud assure le stockage, la gestion et la protection des données sensibles grâce à une infrastructure flexible, sécurisée et capable de s'adapter à la croissance du projet.
- **Applications / Interfaces** : Pour exploiter la valeur des données collectées (optimisation, fidélisation, innovation), une application IoT permet de les relier, les analyser et piloter efficacement les objets et processus de l'entreprise.

1.5 Importance de la sécurité dans l'IoT

Pourquoi la sécurité est cruciale pour l'IoT?

▪ Enjeu central de sécurité

- Données sensibles collectées par les objets connectés
- Objets interconnectés → **vulnérabilité en cascade**
- Attaques possibles : vol de données, prise de contrôle

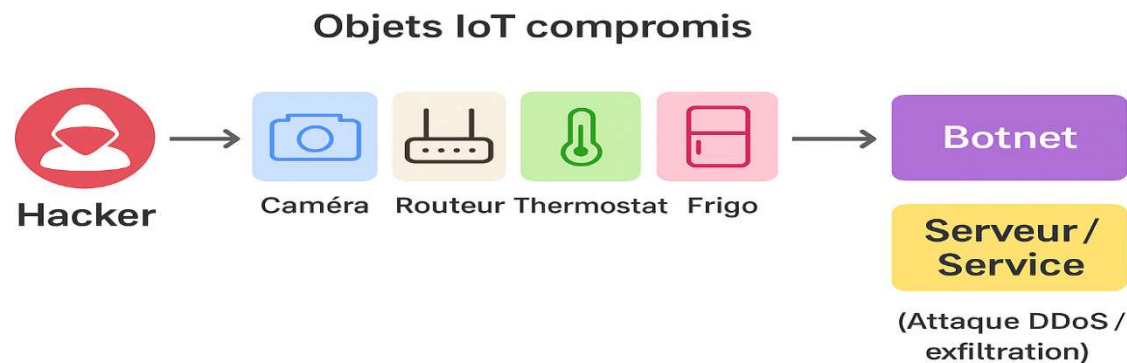
▪ Impacts concrets d'attaques IoT

- Vie privée compromise : données personnelles exposées
- Disponibilité des services : attaques DDoS, interruption de fonctionnement
- Sécurité des personnes : contrôle de dispositifs critiques (voitures connectées, caméras, dispositifs médicaux)

1.5 Importance de la sécurité dans l'IoT

Pourquoi sécuriser l'IoT?

Exemple: Botnet Mirai (2016) : il s'agit d'un réseau de caméras connectées, routeurs et autres objets IoT piratés pour former un **botnet**. Ce réseau a été utilisé pour lancer des **attaques DDoS massives (Distributed Denial of Service)** sur Internet, notamment contre le fournisseur DNS **Dyn**, provoquant la panne temporaire de sites majeurs comme **Twitter, Netflix, GitHub et Airbnb**.



1.6 Attaques emblématiques dans l'IoT

Mirai (2016)

- **Cible** : caméras IP, routeurs.
 - **Mécanisme** : utilisation de mots de passe par défaut → création d'un botnet.
 - **Conséquence** : attaques DDoS massives → panne de grands sites (Netflix, Twitter).
- changer les identifiants par défaut, mettre à jour les firmwares.

Piratage de voitures connectées (Jeep, 2015)

- **Cible** : système de divertissement embarqué.
 - **Mécanisme** : attaque à distance via Internet → contrôle du véhicule.
 - **Conséquence** : risque pour la sécurité des occupants.
- tests de sécurité embarquée,

Détournement de caméras IP

- **Cible** : caméras domestiques mal configurées.
 - **Mécanisme** : accès via mots de passe faibles ou interfaces exposées.
 - **Conséquence** : atteinte à la vie privée, espionnage.
- configurer les accès, activer le chiffrement, isoler le réseau IoT.

1.7 Les services de sécurité IoT

Confidentialité – assurer que les données sont compréhensibles uniquement par les entités autorisées.(ex. chiffrement des capteurs).

Intégrité – assure que toute modification des données sera détecté. (ex. signature des messages).

Authentification –Consiste à vérifier les identités des entités; assurer le fonctionnement continu des objets (ex. éviter les DDoS).

Traçabilité (Auditabilité) : suivre les actions et les événements (journalisation dans le cloud).

Contrôle d'accès fin (Fine-Grained Access Control) : droits spécifiques par utilisateur ou appareil.

Sécurité matérielle : protéger les composants physiques (TPM, PUF, Secure Element).

CHAPITRE 2: Sécurité de la couche physique

1. Introduction
2. Analyse des menaces et attaques
3. Sécurité de la couche physique

2.1 Introduction à La couche Physique

La Couche physique

- **Rôle principal** : Assure la **collecte et la transmission des données** issues du monde réel à travers divers capteurs et dispositifs connectés (Arduino, ZigBee, RFID, codes-barres...).
- **Services clés** :
 - Acquisition de données : capte les paramètres physiques de l'environnement (température, mouvement, etc.).
 - Communication de base : transmet les données vers les autres nœuds ou la couche réseau.
 - Identification et authentification : attribue un identifiant unique (UUID) à chaque objet pour une communication sécurisée.
 - Synchronisation et coordination : gère le timing et les interactions entre dispositifs.
 - Pré-traitement léger : filtre ou convertit les données avant leur envoi pour réduire la

2.1 Introduction à la couche Physique

La couche physique:

Elle correspond au **niveau matériel** du système et gère la **transmission des bits** sur le support physique (câble, fibre optique, ondes radio, etc.).

Éléments clés :

- Composants matériels : capteurs, actionneurs, antennes, circuits intégrés, modules radio...
- Fonction principale : convertir les signaux numériques en signaux physiques (et inversement).
- Vulnérabilités : les attaques ciblent directement le **matériel** ou le **signal** (interférences, sabotage, écoute, etc.).

2.2 Analyse des menaces et attaques

Typologie des attaques de la couche physique

Attaques physiques sur la couche matérielle

Attaque	Effets	Contre-mesures	Détails / Mesures
Nœud compromis	Altération ou destruction des données par capteurs endommagés.	Matériel sécurisé	Boîtiers scellés, détecteurs d'ouverture, composants inviolables pour empêcher toute modification physique.
Dommages physiques	Sabotage ou destruction des équipements IoT.	Protection physique	Surveillance des dispositifs, boîtiers résistants, détecteurs d'intrusion et blindage des zones critiques.
Injection de nœuds	Introduction de dispositifs non autorisés dans le réseau.	Démarrage sécurisé	Vérification de l'intégrité logicielle (signature numérique) avant exécution pour bloquer tout matériel non autorisé.

2.2 Analyse des menaces et attaques

Typologie des attaques de la couche physique

Attaques radio et de communication

Attaque	Effets	Contre-mesures	Description / Détails
Brouillage radio (Jamming)	Interruption ou blocage de la communication entre nœuds.	Canal sécurisé / FHSS / IPSec	Saut de fréquence, redondance de canal et chiffrement pour limiter les interférences.
Interface RF / RFID compromise	Interception ou perturbation du signal radio.	Authentification de l'appareil	Vérifier l'identité du dispositif avant toute émission ou réception de données.
Privation de sommeil (Sleep Deprivation)	Épuisement de la batterie des nœuds IoT.	Authentification & gestion énergétique	Ne répondre qu'aux requêtes légitimes et gérer intelligemment le mode veille.
Accès non autorisé aux balises	Modification ou suppression des métadonnées réseau.	Authentification forte & chiffrement	Protéger les balises par certificats, clés symétriques ou permissions restreintes.

2.2 Analyse des menaces et attaques

Typologie des attaques de la couche physique

Attaques humaines et sociales

Attaque	Effets	Contre-mesures	Détails / Mesures
Ingénierie sociale	Fuite d'informations sensibles ou manipulation du personnel.	Formation & politique de sécurité	Sensibiliser le personnel, appliquer des procédures d'accès strictes et une gestion rigoureuse des identifiants.

Pour mieux comprendre et évaluer ces attaques, il est nécessaire de recourir à des approches de modélisation des menaces, permettant de classer et de prioriser les risques selon leur impact.

2.2 Analyse des menaces et attaques

Modélisation des menaces (Threat Modeling)

- **Objectif** : Identifier, comprendre et anticiper les **risques de sécurité** affectant les dispositifs et environnements IoT.
- **Fonction** : Analyser les **menaces potentielles**, évaluer leur **impact**, puis **hiérarchiser** les contre-mesures et actions préventives.
- **Méthodologies et taxonomies majeures** :
 - **STRIDE (Microsoft)** : Classification des menaces selon leur nature.
 - **Open Threat Taxonomy (OTT)** Référentiel ouvert de typologie des menaces.
 - **UIT-T X.800** : Norme internationale de sécurité des systèmes.
 - **ENISA** (European Union Agency for Cybersecurity): recommandations européennes pour la sécurité IoT.
 - **OWASP** (Open Web Application Security Project): bonnes pratiques pour les applications web et IoT.

2.2 Analyse des menaces et attaques

Modélisation des menaces

Comparaison des modélisations selon leur rôle dans la couche physique IoT

Méthodologie	Rôle dans la couche physique	Points forts	Limites
STRIDE (Microsoft)	Classe les menaces selon leur nature (DoS, altération, etc.)	Catégorise les attaques physiques (brouillage, sabotage)	Peu adaptée aux contraintes matérielles et énergétiques
Open Threat Taxonomy (OTT)	Fournit un vocabulaire commun pour les menaces IoT	Utile pour recenser les attaques matérielles	Pas de hiérarchie ni d'analyse technique
UIT-T X.800	Définit un cadre général de sécurité réseau	Base normative pour la sécurité matérielle	Trop générique, peu orientée IoT
ENISA IoT Taxonomy	Classe les menaces selon les couches IoT	Spécifique à l'IoT (sabotage, brouillage, interférences)	Descriptive, sans évaluation du risque
OWASP IoT	Cible la sécurité logicielle et applicative	Bonnes pratiques (firmware, identifiants, MAJ)	Peu adaptée aux attaques physiques (radio, matériel)

2.2 Analyse des menaces et attaques

Modélisation des menaces

Comparaison des modélisations selon leur rôle dans la couche physique IoT

- **ENISA** aide à identifier les menaces globales selon le contexte IoT (quoi et où protéger). Elle analyse de manière **organisationnelle et contextuelle** en se concentrant sur les actifs, les risques et les scénarios d'attaque.
- **STRIDE** aide à classifier et analyser **techniquement** ces menaces (usurpation, altération, DoS, etc.) (comment elles se produisent et comment les contrer).
- Les autres référentiels (**OWASP**, **UIT-T X.800**, **OTT**) complètent l'analyse pour les **couches réseau et application**.

2.2 Analyse des menaces et attaques

Modélisation des menaces

Modèle STRIDE (Microsoft)

- **Objectif** : identifier les différents types de menaces sur un système.

Spoofing

(usurpation d'identité) : Un attaquant se fait passer pour un autre appareil IoT.

Tampering (altération) : Un attaquant modifie les données transmises entre les dispositifs.

Repudiation (repudiation): L'attaquant nie une action (ex. suppression de logs).



Elevation of Privilege

(élévation de privilèges) : Un attaquant obtient des privilèges plus élevés sur un dispositif IoT.

Denial of Service (DoS) :

Un attaquant rend un appareil IoT ou un service inutilisable.

Information Disclosure

(divulgaration d'informations) : Un attaquant accède à des données sensibles.

2.2 Analyse des menaces et attaques

Modélisation des menaces



Exemple : Un capteur IoT industriel (température, pression, etc.) est déployé sur site. Il communique par ZigBee ou LoRa, et peut être physiquement accessible à un attaquant.

Menace physique (ENISA)	Catégorie STRIDE	Effets / Impacts	Contre-mesures principales
Altération matérielle (modification du circuit, remplacement capteur)	T – Tampering	Données faussées, perte d'intégrité du système	Boîtiers scellés, détection d'ouverture, matériel inviolable
Sabotage / destruction (endommagement du capteur ou alimentation)	D – Denial of Service	Perte de disponibilité, interruption du service	Boîtiers robustes, redondance matérielle, surveillance physique
Accès non autorisé aux ports (JTAG, série, USB)	S / E – Spoofing / Elevation of Privilege	Extraction du firmware ou clés, usurpation d'identité	Désactivation des ports debug, chiffrement firmware, Secure Boot
Interférences électromagnétiques / Jamming	D – Denial of Service	Blocage ou perturbation du signal radio	Saut de fréquence (FHSS), détection de brouillage, canaux alternatifs
Espionnage du signal (sniffing RF)	I – Information Disclosure	Interception de données physiques transmises	Chiffrement radio (AES), authentification mutuelle, contrôle de portée

2.2 Analyse des menaces et attaques

Modélisation des menaces

STRIDE et Services de Sécurité (IoT)

Catégorie STRIDE	Service de sécurité associé	Exemple concret (IoT – Couche Physique)
S – Spoofing (Usurpation d'identité)	Authentification	Vérifier l'identité des capteurs via certificats ou clés partagées pour éviter qu'un faux capteur envoie de fausses données.
T – Tampering (Altération)	Intégrité	Détection d'ouverture du boîtier ou de modification du circuit (capteur saboté ou remplacé).
R – Repudiation (Négation d'action)	Traçabilité / Non-répudiation	Journaliser les accès physiques (ex. maintenance, intervention humaine) pour prouver l'origine d'une action.
I – Information Disclosure (Divulcation d'informations)	Confidentialité	Chiffrement des signaux radio (ex. AES pour ZigBee/LoRa) afin d'éviter l'espionnage ou la capture de données.
D – Denial of Service (DoS) (Indisponibilité)	Disponibilité	Protection contre le brouillage radio (FHSS) ou ajout de redondance matérielle.
E – Elevation of Privilege (Escalade de privilèges)	Contrôle d'accès / Autorisation	Limiter les droits d'accès au port JTAG ou aux interfaces physiques (ex. Secure Boot, verrouillage firmware).